Universidad Michoacana de San Nicolás de Hidalgo

Facultad de Ingeniería Eléctrica

Redes de Computadoras II

Práctica #9: Ataques a la LAN

Profesor:
M.C. Manuel Eduardo Sánchez Solchaga

Alumno:
Juan Diego Torres Cornelio

Introducción

El modelo OSI está dividido en siete capas, las cuales trabajan de forma independiente una de la otra. Los administradores de red, por lo general, implementan soluciones de seguridad para proteger los componentes de la capa 3 hasta la capa 7; entre estas soluciones están las VPN, firewalls, dispositivos IPS, entre otras. Sin embargo, si la capa 2 se ve comprometida, todas las capas superiores también se ven afectadas.

La capa 2 es considerada el enlace más débil, debido a que las LAN estaban tradicionalmente bajo el control administrativo de una sola organización; se confiaba inherentemente en todas las personas y dispositivos conectados. Hoy en día con la política BYOD (*Bring Your Own Device*) y ataques más sofisticados, las LAN se han vuelto más vulnerables a la penetración.

Objetivo

Realizar dos tipos de ataques a la LAN. Un ataque será de VLAN, el cual será *VLAN Double-Tagging*. Por otro lado, realizar un ataque de ARP, el cual será *ARP Poisoning*. Al final, para ambos tipos de ataques, realizar la respectiva mitigación.

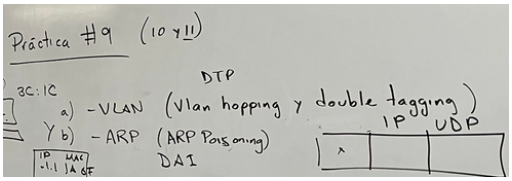


Figura 1: Ataques a la LAN.

1. Ataque de VLAN

El ataque de VLAN Double-Tagging consiste en el que un atacante, en situaciones específicas, podría insertar una etiqueta 802.1Q oculta dentro de la trama que ya tiene una etiqueta 802.1Q. Esto permite que la trama se envíe a una VLAN que la etiqueta 802.1Q externa no especificó.

Definimos la topología donde se realizará el ataque de VLAN Double-Tagging. Véase la figura 2.

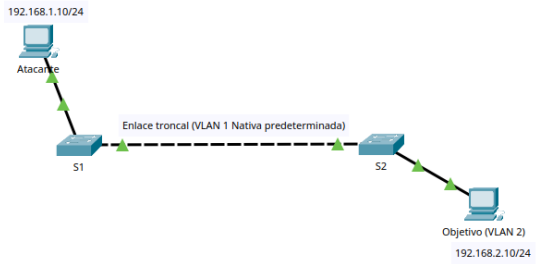


Figura 2: Topología para el ataque de VLAN.

Paso 1

Comenzamos por establecer un vínculo troncal con la PC del atacante y el switch S1. Aprovechamos la vulnerabilidad de que el switch tiene sus configuraciones predeterminadas, por lo que tiene establecido la VLAN 1 como la nativa y el protocolo DTP (*Dynamic Trunking Protocol*) activado. Esto implica que cualquier puerto esté asociado a la VLAN 1 de forma predeterminada y se permita la negociación DTP.

Por lo tanto, al conectarnos al puerto `Fa0/1` (puede ser cualquiera), podemos utilizar el software *Yersinia* para negociar con el protocolo DTP y establecer un enlace troncal. Para ello, ejecutamos Yersinia con el comando `sudo yersinia -I`. Después, elegimos el modo de ataque DTP presionando `F5`. Luego, presionamos `x` para entrar al panel de ataque y escogemos la opción 1 (*enabling trunking*) para iniciar la negociación DTP. Véase la figura 3.

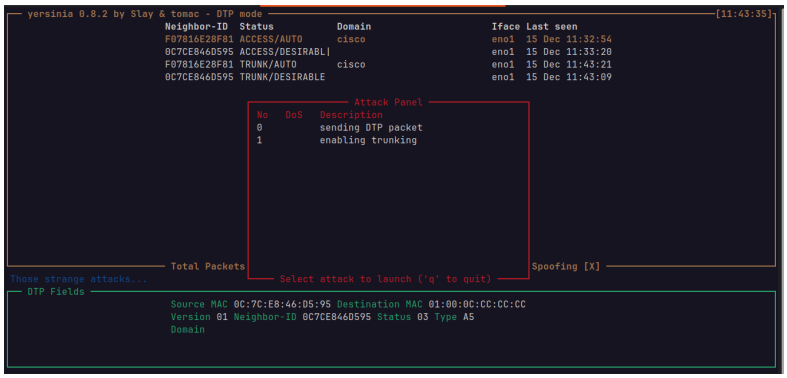
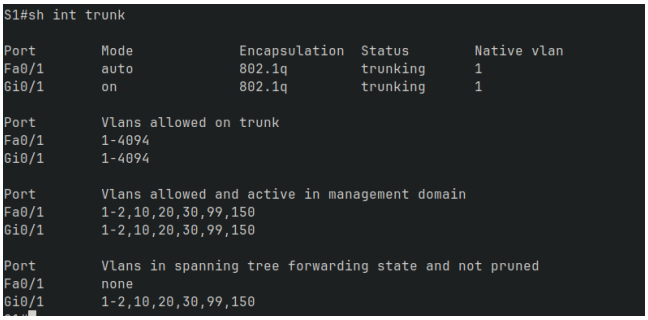


Figura 3: Negociación DTP para establecer enlace troncal con Yersinia.

Una vez establecido el enlace troncal con Yersinia entre la PC del atacante y el switch S1 mediante la negociación DTP, en el switch podemos verificar qué enlaces troncales hay, a través del comando `show interfaces trunk` en el modo privilegiado. Véase la figura 4.



```
S1#sh int trunk

Port        Mode             Encapsulation  Status        Native vlan
Fa0/1       auto             802.1q         trunking      1
Gi0/1       on               802.1q         trunking      1

Port        Vlans allowed on trunk
Fa0/1       1-4094
Gi0/1       1-4094

Port        Vlans allowed and active in management domain
Fa0/1       1-2,10,20,30,99,150
Gi0/1       1-2,10,20,30,99,150

Port        Vlans in spanning tree forwarding state and not pruned
Fa0/1       none
Gi0/1       1-2,10,20,30,99,150
```

Figura 4: Enlace troncal formado con la PC del atacante.

Como se puede ver en la figura anterior, el enlace troncal con la PC del atacante en el puerto `Fa0/1` fue realizado correctamente.

Paso 2

Lo siguiente a realizar es el envío de una trama 802.1Q con doble etiqueta al switch S1. La etiqueta externa llevará la VLAN del atacante, que es la misma que la VLAN nativa (VLAN 1) del puerto del enlace troncal. Para la etiqueta interna, esta será la VLAN víctima (VLAN 2, véase la figura 2).

Para ello, nuevamente utilizamos Yersinia. Escogemos el modo de ataque 802.1Q con `F3`. Después, presionamos `e` para editar los campos de la trama 802.1Q y asignamos al atributo de *VLAN* (etiqueta externa) el valor 1, al atributo *VLAN2* (etiqueta interna) el valor 2 y al atributo *Dst IP* por la dirección IP de la PC objetivo, la cual es `192.168.2.10`; el atributo *Src IP* lo podemos

dejar con la dirección IP predeterminada (`10.0.0.1`) para identificar la trama con más facilidad en *Wireshark*. Una vez editado los campos de la trama 802.1Q, presionamos **`Enter`** y luego con **`x`** escogemos la opción 1 (*sending 802.1Q double enc. packet*) para iniciar el envío de la trama. Véase la figura 5.

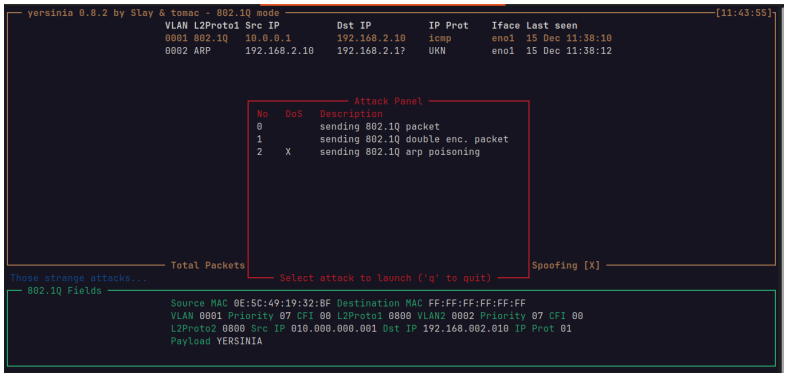


Figura 5: Envío de trama 802.1Q con doble etiqueta.

Podemos capturar esta trama 802.1Q a través de Wireshark desde la PC del atacante. Como se puede ver en la figura 6, la trama contiene dos etiquetas 802.1Q.

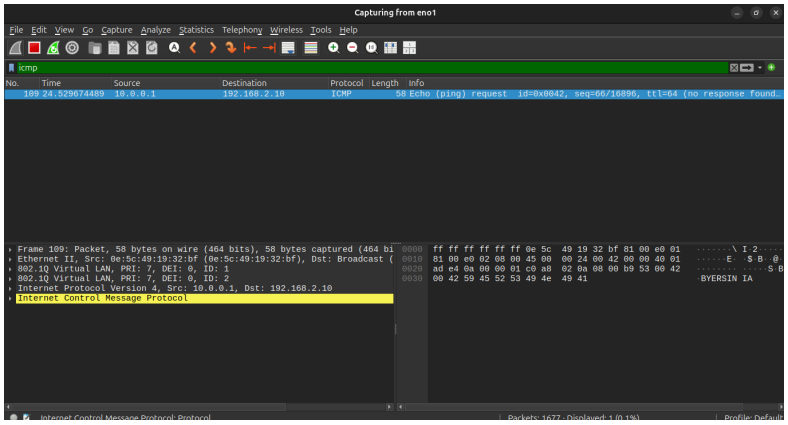


Figura 6: Trama 802.1Q capturada en Wireshark en la PC del atacante.

Cuando la trama 802.1Q llega al switch S1, mira la etiqueta externa y ve que la trama está destinada para la VLAN 1, la cual es la VLAN nativa. Entonces, el switch S1 reenvía la trama a todos los puertos de VLAN 1, despueś de quitar la etiqueta externa. La trama no es re-etiquetada debido a que es parte de la VLAN nativa.

Cuando la trama 802.1Q llega al switch S2 (que no tiene conocimiento de que debía ser para la VLAN 1 nativa), el switch solo observa la etiqueta interna,

que el atacante insertó, y ve que la trama está destinada para la VLAN 2. Por consiguiente, el switch S2 remueve la etiqueta interna y reenvía la trama al puerto victima o lo satura, dependiendo de si existe una entrada en la tabla MAC para el host víctima.

La figura 7 muestra el estado de la trama 802.1Q al llegar a la PC objetivo. Como se puede apreciar, la trama ya no contiene tanto la etiqueta externa e interna dado que ambos switches han ido eliminando la etiqueta más externa durante el transcurso de la trama.

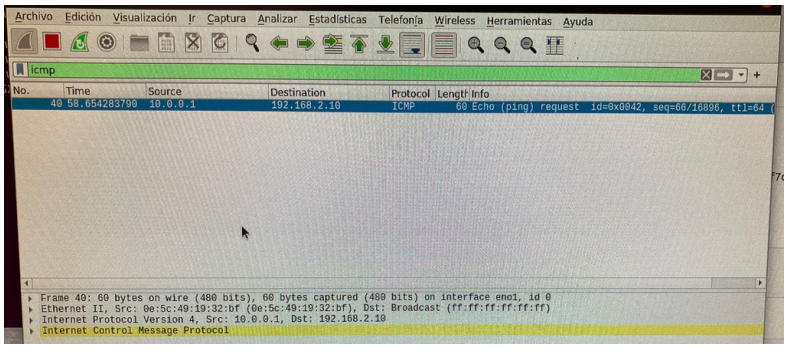


Figura 7: Trama 802.1Q capturada en Wireshark en la PC objetivo.

Podemos concluir que el ataque de VLAN Double-Tagging ha funcionado con éxito. Este ataque abre la posibilidad de poder realizar una denegación de servicio hacia otros departamentos de una organización al saturar la red con el envío constante constante de tramas 802.1Q.

Mitigación

El ataque de VLAN Double-Tagging se puede evitar a través de la implementación de pautas de seguridad troncal. A continuación, se muestran las siguientes pautas:

- **Deshabilitar troncal en todos los puertos de acceso:** Para ello, podemos utilizar el comando:

  ```
  switchport mode access
  ```

  en el modo de configuración de interfaz. Esto se aplica en aquellas interfaces que conecten con dispositivos finales.

- **Deshabilitar entroncamiento automático en enlaces troncales para poder habilitarlos de forma manual:** Se puede realizar esto en ambas interfaces que formen un enlace troncal mediante el comando:

  ```
  switchport nonegotiate
  ```

  en el modo de configuración de interfaz.

- **Asegurarse de que la VLAN nativa solo se usa para enlaces troncales:** Para esto, podemos crear una VLAN, distinta a la VLAN 1, para fines de funcionamiento exclusivo de ser nativa. Por ejemplo, podemos crear la VLAN 99 para que sea la VLAN nativa. Una vez creada, en el modo de configuración de interfaz para ambas interfaces que formen un enlace troncal, utilizamos el comando:

  ```
  switchport trunk native vlan 99
  ```

  donde se especifica la VLAN 99 ahora como la nativa.

2. Ataque ARP

Los hosts transmiten una solicitud ARP a otros hosts del segmento de red para determinar la dirección MAC de un host con una dirección IP específica. Esto se utiliza para descubrir la dirección MAC de una puerta de enlace predeterminada. Todos los hosts de la subred reciben y procesan la solicitud ARP. El host con la dirección IP que coincide con la dirección de la solicitud ARP, envía una respuesta ARP.

Cualquier cliente puede enviar una respuesta ARP no solicitada llamada *ARP gratuito*, según el ARP RFC. Cuando un host envía un ARP gratuito, otros hosts en la subred almacenan en sus tablas ARP la dirección MAC y la dirección IP que contiene dicho ARP.

Un atacante podría enviar un ARP gratuito al switch, y el switch podría actualizar su tabla MAC de acuerdo a este mensaje. Por lo tanto, el atacante podría enviar una respuesta ARP gratuita a otros hosts en la subred con la dirección MAC del atacante, pero con la dirección IP de la puerta de enlace predeterminada. A este ataque se le conoce como *ARP Poisoning*.

Comenzamos por definir la topología donde se implementará el ataque. Véase la figura 8.

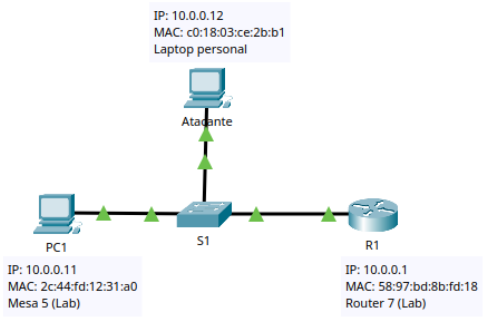


Figura 8: Topología para el ataque ARP.

El objetivo es envenenar la tabla ARP tanto de la PC1 como del router R1. El

tráfico que la PC1 quiera enviar a R1, en realidad se nos estará enviando hacia nosotros (PC Atacante). Por otro lado, el tráfico que el router R1 quiera enviar a la PC1, nos estará llegando a nosotros de igual manera.

Para realizar este ataque, utilizaremos la herramienta *Ettercap*. Ejecutamos la herramienta con el comando:

```
sudo ettercap -G
```

Una vez iniciada, confirmamos la interfaz y seleccionamos el apartado *Hosts List*. Procedemos a realizar un escaneo en el ícono de lupa llamado *Scan for hosts*. Ettercap detectará dos equipos en la subred, la PC1 con dirección `10.0.0.11` el router R1 con dirección `10.0.0.1`. Después del escaneo, seleccionamos la dirección `10.0.0.11` como *target 1* y la dirección `10.0.0.1` como *target 2*. Finalmente, seleccionamos en la pestaña MITM (ícono de mundo) la opción *ARP poisoning* para iniciar el ataque. Véase la figura 9.

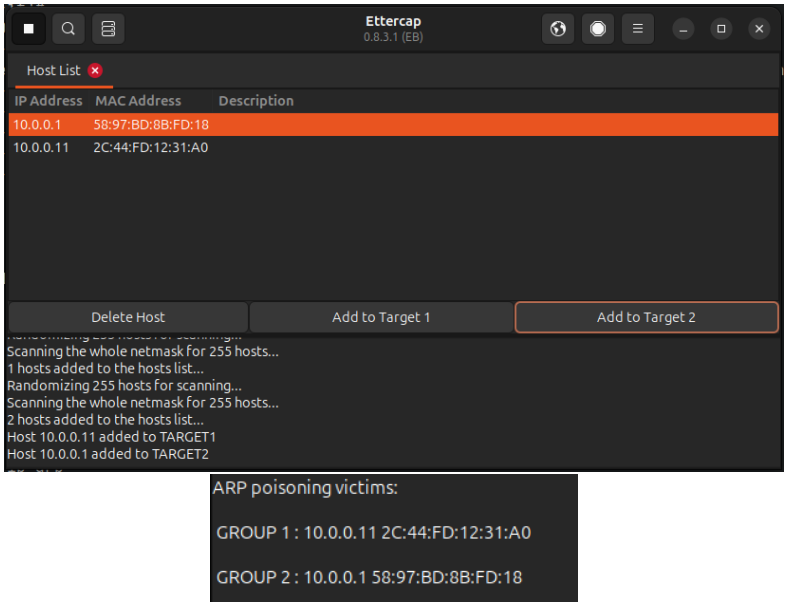


Figura 9: Ataque ARP poisoning en Ettercap.

Realizado lo anterior, Ettercap estará enviando las respuestas ARP gratuitas, provocando que las tablas ARP sean envenenadas.

Si realizamos un ping desde la PC1 hacia el router R1, aparentemente todo está bien. Sin embargo, si visualizamos con Wireshark desde la PC del atacante, podremos observar que los paquetes ICMP, que corresponden al ping de la PC1, los estamos recibiendo nosotros con dirección de origen `10.0.0.11` y dirección de destino `10.0.0.1`. Véase la figura 10.

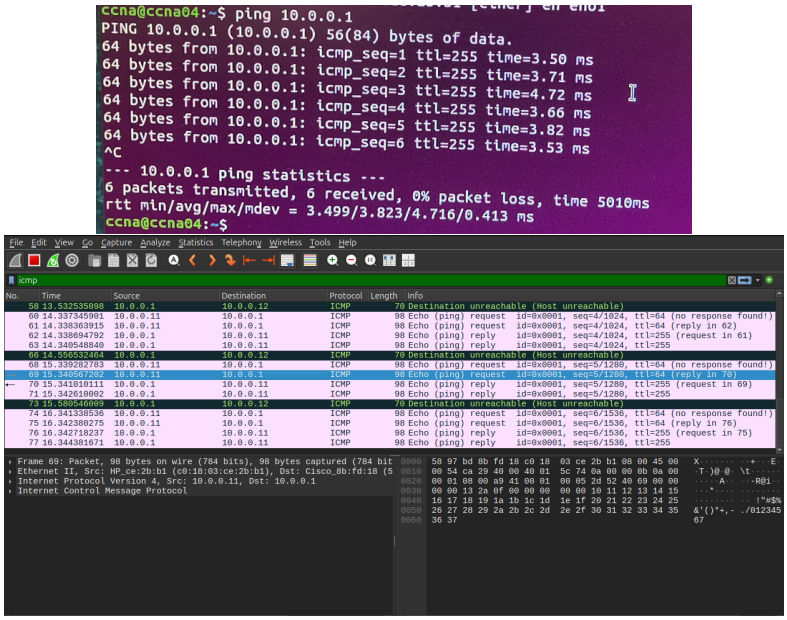


Figura 10: Tráfico de la PC1 hacia R1 siendo recibido por PC del atacante.

Si visualizamos la tabla ARP de la PC1[1], nos daremos cuenta que la dirección que tiene registrada para el router R1, `10.0.0.1`, está asociada con la dirección MAC de la PC del atacante, `c0:18:03:ce:2b:b1`. Véase la figura 11.

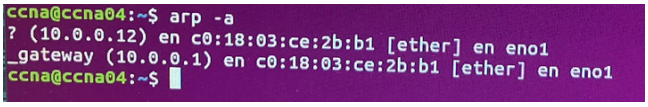


Figura 11: Tabla ARP de la PC1 envenenada.

De igual forma, si visualizamos la tabla ARP del router R1[2], nos daremos cuenta que la dirección que tiene registrada para la PC1, `10.0.0.11`, está asociada con la dirección MAC de la PC del atacante, `c0:18:03:ce:2b:b1`. Véase la figura 12.

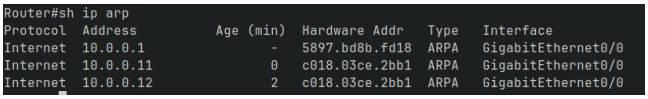


Figura 12: Tabla ARP del router R1 envenenada.

Este tipo de ataque abre la posibilidad de realizar un ataque derivado, como

[1] En Linux, puede consultarse con el comando `arp -a`.

[2] Puede consultarse la tabla con el comando `show ip arp`, en el modo de configuración provilegiado.

un *Man In The Middle*, en el que se puede interceptar y observar el tráfico que ocurre durante una conexión mediante telnet con los dispositivos de red, esto por poner un ejemplo.

Mitigación

Para evitar el envenenamiento por ARP, debemos garantizar que solo se transmitan las solicitudes y respuestas ARP válidas. La inspección dinámica (DAI, *Dynamic ARP Inspection*) permite mitigar las probabilidades de ARP Poisoning a través de las siguientes pautas, las cuales son implementadas en el switch S1 (véase figura 8):

- **Habilitar la detección de DHCP:** DAI requiere del servicio *DHCP Snooping*:

  ```
  S1(config)# ip dhcp snooping
  ```

- **Habilitar la detección de DHCP en las VLAN seleccionadas:** En nuestro caso, solo contamos con la VLAN 1, por lo que ejecutamos:

  ```
  S1(config)# ip dhcp snooping vlan 1
  ```

- **Habilitar el DAI en las VLANs seleccionadas:** De igual forma como en la pauta anterior, solo contamos con la VLAN 1, entonces:

  ```
  S1(config)# ip arp inspection vlan 1
  ```

- **Configurar las interfaces de confianza para la detección de DHCP y la inspección de ARP (≪no confiable≫ es la configuración predeterminada):** Para esta pauta, se tiene que el switch S1 conecta con el router R1 a través del puerto `Gig0/1`, por lo que esté será nuestra interfaz de confianza. Ejecutamos el comando:

  ```
  S1(config)# interface Gig0/1
  S1(config-if)# ip dhcp snooping trust
  S1(config-if)# ip arp inspection trust
  ```

DAI se puede configurar para revisar si hay direcciones MAC e IP de destino o de origen. Ejecutamos el comando:

```
S1(config)# ip arp inspection validate src-mac dst-mac ip
```

Lo anterior permite verificar si las direcciones MAC en el cuerpo de los paquetes ARP no coinciden con las direcciones que se especifican en el encabezado Ethernet.

El flujo de la inspección DAI en el switch es el siguiente:

1. Intercepta todas las solicitudes y respuestas ARP en puertos no confiables.

2. Verifica que cada uno de estos paquetes interceptados tenga un enlace de dirección IP a MAC válido antes de actualizar la memoria caché ARP local o antes de reenviar el paquete al destino apropiado.

3. Interrumpe paquetes ARP no válidos.

En resumen, la inspección de ARP dinámica determina la validez de un paquete ARP según las vinculaciones de dirección IP a dirección MAC válidas almacenadas en una base de datos confiable, la base de datos de vinculación de DHCP Snooping. Esta base de datos se compila mediante DHCP Snooping si está activada en las VLAN y en el switch. Si el paquete ARP se recibe en una interfaz confiable, el switch reenvía el paquete sin ninguna comprobacaión.

Referencias

1. https://www.youtube.com/watch?v=-0Bvwl8QZUY
2. https://dspace.ups.edu.ec/bitstream/123456789/25188/1/UPS-CT010622.pdf
3. https://linux-audit.com/how-to-clear-the-arp-cache-on-linux/
4. https://www.cisco.com/c/es_mx/support/docs/switches/lan-switch-software/222274-troubleshoot-dynamic-arp-inspection-dai.html